API conventions

English version of ../../api/conventions.md.

Rules

Rule	Detail
Format	JSON for `/api/*`, HTML for pages
Authentication	cookie session `session_id` (HttpOnly, SameSite=lax)
Admin access	`/api/auth/admin-login` with the code from `ADMIN_CODE`; without the variable — 503
Validation	Pydantic models plus explicit format checks (phone, e-mail)
Errors	`{"detail": "..."}` (FastAPI), codes 400/401/403/409/503
CORS	`CORS_ORIGINS` (comma-separated); same-origin only by default

Routes

Method	Path	Purpose
POST	`/api/auth/check-phone`	is the phone number already taken
POST	`/api/auth/register`	sign-up, issues the session cookie
POST	`/api/auth/login`	sign-in
POST	`/api/auth/admin-login`	role elevation with the code from the environment
POST	`/api/auth/logout`	sign-out, session is deleted
GET	`/api/auth/current-user`	current user
GET	`/api/auth/users`	user list
POST	`/api/session/save`, `/api/session/data`	quiz state round-trip
POST	`/api/quiz/submit`	quiz request
GET	`/api/quiz/submissions`	recent requests
GET	`/api/admin/submissions`	all requests (admin)
PUT	`/api/admin/submissions/{id}`	change status (admin)

Error codes

Code	When
400	bad format (phone, e-mail), no consent, short password
401	missing or expired session, wrong admin code
403	the user is not an administrator
409	phone or nickname already taken
503	admin sign-in is not configured (`ADMIN_CODE` is empty)

How to change the API

1. Change the route or the model. 2. Update `static/*.js`. 3. Run `make test lint` (the tests describe the contract). 4. Add a row to verification/matrix.md.